

Mitigação com Escopo de DDoS de Camada de Aplicação com um Grafo de Conhecimento Centrado na Sessão

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre e Eder John Scheid
Instituto de Informática, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brasil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

Resumo—Um Slow HTTP DoS distribuído mantém cada origem abaixo de qualquer limiar por origem. Sinalizar o *endpoint* atacado exige pouco mais que contar origens; a decisão difícil é quais clientes bloquear sem bloquear os próprios usuários do serviço, e a resposta natural é prejudicial. Modelamos a sessão HTTP como entidade de primeira classe de um grafo de conhecimento OWL, ligada a outras sessões por seis sub-propriedades ponderadas pelo custo de evasão; uma única regra SPARQL/SWRL deriva veredicto, evidência e escopo. Em campanhas furtivas geradas, a detecção por sessão fica no acaso, enquanto atributos entre sessões alcançam ROC AUC 0,93–0,98. Definir o escopo pela impressão digital TLS mais comum do agrupamento bloqueia 0% de uma *botnet* espalhada por várias pilhas e 39% do tráfego legítimo; um teste binomial de enriquecimento contra o tráfego normal bloqueia 90% sem colateral observado e sem rótulo, igualando um modelo aprendido que recebe o perfil e os rótulos da campanha. Em oito dias de tráfego de uma CDN o teste nomeia pilhas da *botnet* que clientes reais também apresentam, o que um filtro de impressões digitais inéditas não consegue, e dispara em 4% dos *flash crowds* contra 65% de um *z-score*. Unido a esse filtro atrás de um gatilho de origens distintas, detém 38 a 78% de 100 a 1000 atacantes injetados por janela (20 a 62% em pilhas compartilhadas) e dispara em 0,1% das janelas limpas, onde bloqueia uma mediana de 30% dos clientes. O grafo justifica seu lugar: sua consulta de contagens compilada reproduz, janela a janela, a exportação de um dia de produção, um sinal novo custa quatro triplas e nenhum código, e a exportação STIX 2.1 passa no validador da OASIS em modo estrito.

Index Terms—gestão de segurança, grafo de conhecimento, DDoS de camada de aplicação, modelos semânticos, raciocínio automatizado, explicabilidade, política de mitigação

I. INTRODUÇÃO

Os ataques de negação de serviço distribuída (DDoS) de camada de aplicação continuam crescendo em volume e frequência. Em agosto de 2023, o HTTP/2 Rapid Reset (CVE-2023-44487) levou os picos mitigados a 398 milhões de requisições por segundo a partir de cerca de vinte mil máquinas [1], [2], e a Cloudflare bloqueou mais de 6 500 ataques hiper-volumétricos só no segundo trimestre de 2025 [3]. As defesas volumétricas foram construídas para absorver ataques dessa magnitude, e a detecção fica mais difícil na ponta de baixa taxa do espectro, onde está o *Slow HTTP DoS distribuído*: o Slowloris e seus descendentes, mais variantes baseadas em taxa que ainda

sustentam conexões abertas, como HULK e GoldenEye [4], exaurem um servidor a partir de várias origens coordenadas, cada uma enviando requisições pequenas o bastante para que nenhum limiar por origem seja ultrapassado.

Uma campanha furtiva também molda cada sessão para parecer legítima nos sinais por sessão em que os detectores se apoiam, como duração da conexão e entropia de rotas [5]. O que continua discriminativo vive na estrutura *entre* sessões: a mesma impressão digital de cliente se repetindo em muitas origens, e essas origens convergindo sobre um mesmo *endpoint*. Posto nesses termos, o problema pertence à gestão de redes e serviços tanto quanto à detecção, porque agir sobre ele exige uma decisão: *quais* clientes tratar, com base em *qual* evidência, e com um filtro estreito o bastante para poupar os usuários legítimos do serviço atacado.

O trabalho existente ataca o lado da detecção desse problema e deixa o operacional em aberto. Uma meta-análise de 75 estudos constata que 47% dos detectores de DDoS de camada de aplicação derivam seus atributos de sessões HTTP [6], achatadas em um vetor numérico antes do classificador, que então não consegue raciocinar sobre impressões digitais que se repetem entre origens nem sobre padrões que só existem entre sessões individualmente normais. Detectores baseados em grafos preservam essas relações: o KLAGe [7] constrói grafos de conhecimento a partir de *logs* de rede, classifica nós com Graph-BERT [8] e reporta em linguagem natural, alcançando $F_1 = 84,1\%$ em *benchmarks* de IoT com DDoS Slowloris. Três oportunidades permanecem abertas. Primeiro, a unidade de raciocínio é o *nó de rede* (porta, IP, fluxo), enquanto a coordenação de camada 7 só se torna visível no nível da sessão de aplicação. Segundo, a coordenação é capturada implicitamente, em *embeddings* aprendidos, de modo que nenhum operador consegue inspecionar as relações por trás do veredicto. Terceiro, a saída para o relato, enquanto agir sobre ele exige uma política de mitigação cujo escopo decorra do grafo. Essas três lacunas definem o espaço que este artigo ocupa.

Este artigo as endereça com uma solução baseada em grafos de conhecimento que define o escopo da mitigação de DDoS de camada de aplicação. Ela associa cada requisição

Tabela I
COMPARAÇÃO DOS TRABALHOS RELACIONADOS

Trabalho	Ano	Objetivo	Unidade de Raciocínio	Relação entre Sessões	Explicação do Veredicto	Escopo de Mitigação	Colateral
[9]	2012	DDoS L7	Sessão como Vetor	-	-	-	-
[10]	2015	Anomalias de Fluxo	Estatística de Fluxo	-	-	-	-
[5]	2023	DoS L7	Sessão como Vetor	-	-	-	-
[11]	2024	Dependências entre Dispositivos	Dispositivo de Rede	Implícita (Aprendida)	-	-	-
[12]	2024	Intrusão em TI	Host	Implícita (Aprendida)	-	-	-
[13]	2024	Tráfego de Bots	Impressão Digital JA4	Proprietária	-	Não divulgado	Não divulgado
[7]	2026	Ameaças de Rede	Nó de Rede	Implícita (Aprendida)	A posteriori (LIME/LLM)	-	-
Este Trabalho	2026	DDoS L7 Distribuído	Sessão de Aplicação	Explícita (Tipada e Ponderada)	Derivação	Derivado	Reportado

HTTP/TLS a um nó `ApplicationSession` de um grafo OWL mantido ao longo de uma janela deslizante, liga as sessões por sub-propriedades ponderadas pelo custo que o atacante teria para quebrar cada sinal e dispara uma regra SPARQL/SWRL cuja derivação é o veredicto e cujo discriminador define o escopo da mitigação. O alvo são campanhas conduzidas por *botnets* de dispositivos comprometidos, cujas pilhas TLS seu operador não consegue trocar a baixo custo, e bots que apresentam a impressão digital de um navegador são avaliados como a fronteira do método. Este artigo traz quatro contribuições. (i) Propomos uma ontologia OWL na qual a sessão HTTP é entidade de primeira classe, relacionada a outras sessões por *seis sub-propriedades tipadas* ponderadas pelo custo de evasão, de modo que a proximidade de rede, que *botnets* modernas quebram trivialmente, entra apenas como evidência auxiliar. (ii) Definimos um procedimento de decisão em que uma regra SPARQL/SWRL dispara sobre a massa de coordenação ponderada $\Omega(S)$ de um agrupamento candidato, de modo que o veredicto reportado é a derivação que satisfaz a regra, e mostramos que na escala da janela essa massa age como um gatilho de volume, que uma contagem de origens distintas cumpre ao menos tão bem, com metade dos falsos alarmes no tráfego de produção. (iii) Derivamos o escopo de mitigação do mesmo grafo e o exportamos com sua cadeia de evidência em JSON-LD e STIX 2.1. Mostramos que a escolha natural, a propriedade que a maior parte do agrupamento compartilha, é prejudicial em condições realistas, e a substituímos por um teste binomial de enriquecimento sobre um perfil de tráfego normal, contado em origens a um nível calibrado, que no tráfego de produção nomeia pilhas da *botnet* compartilhadas com clientes reais e raramente dispara em *flash crowds*. (iv) Avaliamos a abordagem contra uma linha de base forte por sessão e contra um modelo aprendido que recebe o mesmo perfil, à medida que a campanha se torna mais distribuída, e sobre oito dias de tráfego de produção, e medimos a taxa de falsos positivos do filtro de mitigação resultante como dano colateral sobre o tráfego legítimo.

A Seção II revisa os trabalhos relacionados, a Seção III apresenta o *framework* e a Seção IV, a metodologia de avaliação. A Seção V reporta os resultados, a Seção VI discute o posicionamento operacional e as limitações, e a Seção VII conclui.

II. TRABALHOS RELACIONADOS

A Tabela I compara este trabalho com o estado da arte em quatro dimensões: a unidade de raciocínio, a representação das

relações entre sessões, a forma da explicação e se um escopo de mitigação e seu custo colateral decorrem dessa representação. As subseções tratam dos grafos de conhecimento de segurança, da detecção de camada 7 e de como ambos tratam as sessões.

A. Grafos de Conhecimento em Segurança e Gestão

A primeira onda de grafos de conhecimento em segurança foi *estática*: entidades extraídas de Common Vulnerabilities and Exposures (CVE), relatórios e *blogs*, normalizadas e ligadas em uma base consultável [14], [15]. Nas palavras de uma revisão da área [16], a lacuna resultante é que “*it is still unclear how to implement the knowledge graph to face real industrial difficulties in cyber attack and defense situations*”. Grafos construídos a partir de texto de inteligência de ameaças não capturam a estrutura do tráfego em tempo de execução.

Trabalhos mais recentes populam grafos a partir do próprio tráfego, e o KLAGE [7] é o mais próximo destes da abordagem aqui proposta. Representações em grafo também vêm ganhando espaço em tarefas adjacentes de gestão: uma linha identifica dependências entre dispositivos por predição de ligações sobre grafos de rede [11], outra aprende sequências de ações de ataque a partir de medições em bancada [12]. Ambas operam sobre entidades de nível de rede, e nenhuma deriva um escopo de mitigação do que encontra.

B. Detecção de DDoS de Camada 7 sobre HTTP

O estado da arte em detecção de DDoS de camada 7 sobre HTTP [4], [17] divide-se em duas categorias: (i) perfilamento estatístico e (ii) aprendizado de máquina. A primeira aplica Análise de Componentes Principais (PCA) a estatísticas de fluxo [10] ou a uma matriz comportamental por sessão [9], sendo esta última uma das primeiras formulações a pôr a sessão no centro, ainda que como vetor de atributos. A segunda categoria, mais recente, aplica aprendizado supervisionado sobre atributos de sessão [5], cujos autores observam que o método não foi validado em tempo real e que sua saída é binária, sem explicação ontológica. Nenhuma das duas categorias preserva uma relação entre sessões: a coordenação existente é dissolvida no vetor de atributos antes que o classificador chegue a vê-la.

C. Modelagem de Sessão em Detecção de Anomalias

Entre os 75 estudos de uma meta-análise sobre o tema [6], nenhum mantém a sessão como objeto com identidade, alvo,

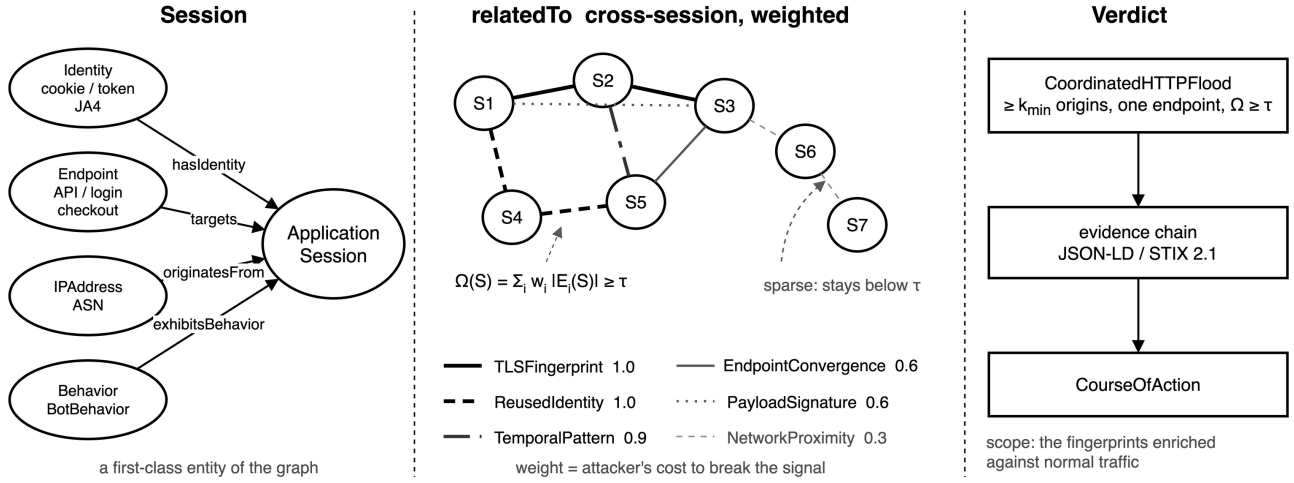


Fig. 1. Ontologia centrada na sessão e regra de detecção. A convergência de *endpoint* liga todo par de sessões do *endpoint*; poucos estão desenhados.

comportamento e relações tipadas. A redução é uniforme, e coloca o raciocínio entre sessões fora do alcance do detector.

Plataformas industriais de gestão de *bots* de fato exploram estrutura entre sessões: sinais agregados por JA4 sobre o tráfego recente alimentam a pontuação de *bots* e a proteção contra DDoS [13]. São proprietárias, sem ontologia pública, sem *benchmark* acadêmico reproduzível e sem métrica formalizada de dano colateral.

A Tabela I torna a fronteira explícita. Detectores estatísticos e de aprendizado de máquina reduzem a sessão a um vetor, de modo que nenhuma relação entre sessões sobrevive e nenhum escopo de mitigação ou custo pode decorrer da decisão. Detectores baseados em grafos preservam relações, sobre entidades de nível de rede e em forma aprendida, e plataformas industriais agem sobre agregados por impressão digital sem divulgar a representação ou o custo de agir sobre ela. Nenhuma abordagem publicada, portanto, reúne três propriedades: a sessão de aplicação como unidade de raciocínio, relações entre sessões explícitas e tipadas, e um escopo de mitigação derivado da representação que produziu o veredicto, com seu dano colateral reportado. O restante deste artigo fornece essa combinação e mede quanto ela custa quando o escopo erra.

III. GRAFO DE CONHECIMENTO CENTRADO NA SESSÃO

A Fig. 1 resume o *framework*. Quatro estágios correm sobre tráfego ao vivo: eventos HTTP são ingeridos, elevados a instâncias da ontologia, com as sessões como nós persistentes do grafo, avaliados por regras semânticas e convertidos em um veredicto que carrega sua cadeia de evidência e o escopo de mitigação derivado.

A. Empregando Grafos de Conhecimento

Um grafo de conhecimento enuncia fatos como triplas RDF (sujeito, predicado, objeto), e uma ontologia OWL 2 declara as classes e propriedades que essas triplas podem usar. Trabalhamos no perfil OWL 2 RL [18], cujo encadeamento progressivo polinomial torna a materialização limitada tratável para raciocínio em tempo de execução, onde OWL 2 DL

não é, e a materialização roda uma vez por janela, fora do caminho por requisição. O SWRL acrescenta regras de Horn, que afirmam uma tripla quando uma conjunção de premissas se verifica, e o SPARQL consulta e agrega o resultado. A identidade do cliente vem do JA4 [19], um *hash* do *ClientHello* TLS que identifica a pilha TLS do cliente. Por ser independente do endereço de origem, ele sobrevive à rotação de IP.

B. Definindo a Ontologia

A classe central é *ApplicationSession*, relacionada por *hasIdentity* a uma *Identity* composta (*cookie*, *token* JWT, nome de usuário, impressão digital TLS), por *originatesFrom* ao seu *IPAddress* de origem, por *targets* a um *Endpoint* (*AuthEndpoint*, *APIEndpoint*, *StaticAsset*), por *exhibitsBehavior* a um perfil comportamental, e por *mitigatedBy* a uma política (*RateLimit*, *Challenge*, *Block*) que carrega um atributo *scope*. A classe abstrata *ApplicationLayerAttack* especializa-se em *SlowHTTPDoSFamily*, por sua vez dividida em *ConnectionExhaustionAttack* (*Slowloris*, corpo lento, leitura lenta) e *CoordinatedHTTPFlood* (*HULK*, *GoldenEye*). A ontologia está alinhada a STIX 2.1 [20] e MITRE ATT&CK, e declara também *CredentialStuffing* e *CoordinatedAPIAbuse*, que reaproveitam a mesma maquinaria mas ficam fora do escopo experimental deste artigo.

C. Modelo de Ameaça

O defensor opera a aplicação atacada e observa, por requisição, o *ClientHello* TLS (logo, uma impressão digital JA4), endereço e prefixo/ASN de origem, *endpoint* alvo, instante de chegada e todo o material de identidade que a aplicação expõe. Ele não vê o canal de controle da *botnet* nem quais origens são coordenadas, mas pode perfilar o tráfego do próprio serviço fora de episódios de ataque. O atacante controla *K* dispositivos comprometidos e pode moldar cada sessão para ser estatisticamente indistinguível de uma legítima, que é a premissa de furtividade da nossa avaliação. O dano é a capacidade esgotada: cada sessão ocupa uma conexão e um

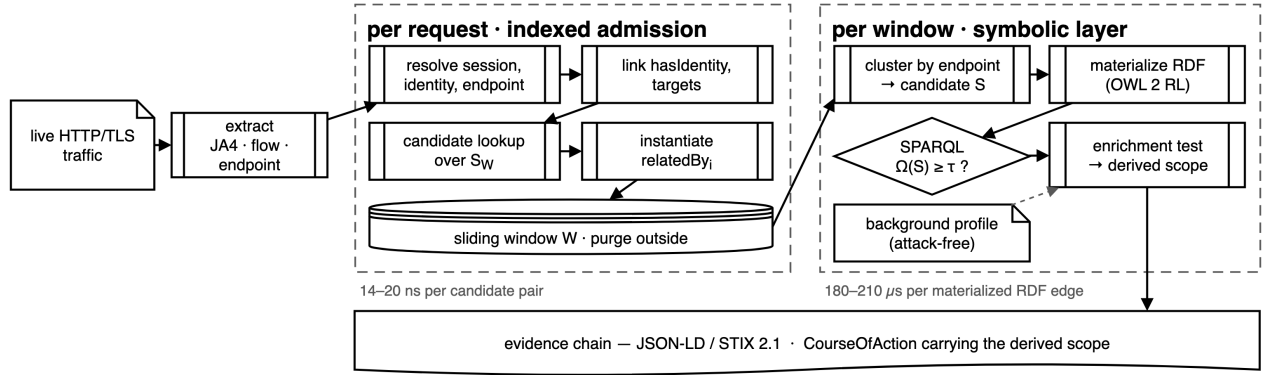


Fig. 2. Pipeline de execução, por requisição e por janela.

worker como uma legítima, de modo que nenhuma taxa por sessão sobe, e a agregada cresce apenas pela fatia da campanha no tráfego do *endpoint*. Temporização, identidades e cargas úteis podem receber ruído, ser rotacionadas ou aleatorizadas, cada uma a um custo operacional que a ponderação da Seção III-D codifica. A pilha TLS é mais difícil de trocar, porque é fixada pela biblioteca que cada dispositivo embarca, como nas *botnets* de roteadores, câmeras e DVRs da linhagem Mirai [21]. Apresentar o *ClientHello* de um navegador exigiria levar uma biblioteca de personificação a cada dispositivo e mantê-la em dia com as versões dos navegadores. Bots que fazem isso, como fazendas de navegadores *headless*, ficam fora deste modelo, e as Seções V-D e VI os avaliam como sua fronteira.

D. A Família *relatedTo* Ponderada

A relação entre sessões é uma família estruturada de relações, declarada via `rdfs:subPropertyOf` sob uma *relatedTo* simétrica e anotada com um `coordinationWeight` $w_i \in [0,1]$, representada na Fig. 1. Cada uma é instanciada de forma independente a partir de sua própria evidência observada, de modo que duas sessões podem ficar ligadas por uma, por várias ou por todas as seis.

A ordenação é um argumento de custo de evasão para esse atacante. Trocar a pilha TLS significa substituir a biblioteca em cada dispositivo, e o JA4 ordena as extensões antes de calcular o *hash*, de modo que permanece estável sob a aleatorização de extensões que o Chrome introduziu em 2023, a qual quebra o JA3 clássico [19]. Reaproveitar identidade é igualmente caro de quebrar, porque espalhar uma campanha por muitas credenciais mina sua economia. A coerência temporal tem origem no modo como a *botnet* é operada, e ruído aleatório pode quebrá-la em parte. Os sinais de carga útil e de *endpoint* são intermediários: aleatorizá-los é barato, mas fazê-lo custa coerência à campanha. A proximidade de rede é o elo mais fraco por construção: derivados do Mirai, frotas em nuvem e redes de *proxy* residencial se espalham por ASNs e prefixos, e o NAT de operadora torna um /24 compartilhado um discriminador pobre. A calibração do Apêndice B corrobora

a ordenação, e não faz afirmação alguma sobre os valores absolutos.

E. Construção do Grafo em Tempo de Execução

Sessões e relações vivem dentro de uma janela operacional deslizante ($W = 5$ min por padrão) e são expurgadas incrementalmente, seguindo uma disciplina de processamento de fluxo RDF, com materialização sobre Apache Jena Fuseki e armazenamento TDB2. A Fig. 2 dispõe as duas camadas e as taxas em que operam, e o Apêndice A traz o algoritmo de construção e o procedimento por par de cada sub-relação *relatedBy*. Casamentos exatos de JA4, de *endpoint* e de prefixo são relações de equivalência, de modo que cada um particiona S em classes e $|E_i(S)| = \sum_k \binom{n_k}{2}$ sobre seus tamanhos n_k em origens. Admitir uma sessão passa então a acrescentar sua origem a uma classe por sub-relação desse tipo, uma inserção em tabela *hash* que não depende de $|S_W|$, e $\Omega(S)$ dispensa arestas de par. Apenas as relações não transitivas (JA4 por variante próxima, temporal, carga útil) comparam pares candidatos, que índices de prefixo e *hashing* sensível à localidade restringem. A Seção V-E mede os dois caminhos contra a ocupação da janela.

F. Regra de Detecção

Seja V_{sess} o conjunto de sessões ativas em W . Para um subconjunto $S \subseteq V_{\text{sess}}$ e um *endpoint* candidato e , define-se a *massa de coordenação*

$$\Omega(S) = \sum_{i \in \mathcal{R}_{\text{rel}}} w_i |E_i(S)|, \quad (1)$$

com $E_i(S)$ o conjunto de pares de origens distintas $\{o(s_a), o(s_b)\}$, $s_a, s_b \in S$, cujas sessões estão ligadas pela sub-relação i , em que $o(s)$ é o endereço de origem de s . Cada par conta uma vez, de modo que as muitas sessões de um cliente não se passam por coordenação. A regra *CoordinatedHTTPFlood* vale quando existe S com (i) ao menos k_{min} origens; (ii) $\forall s \in S : (s, \text{targets}, e) \in E$; e (iii) $\Omega(S) \geq \tau_{\text{cluster}}$. Ela só mitiga quando o teste de enriquecimento da Seção III-H nomeia uma impressão digital; por janela, S é toda sessão para e (Apêndice E).

Na escala da janela, a maior parte dessa massa é volume: sob a condição (ii) o termo de *endpoint* é $0,6\binom{n}{2}$ para n origens e responde por 91% de Ω na campanha da Listagem 2, e com pesos uniformes a regra por janela detecta tão bem quanto com estes. Um limiar sobre as origens distintas da janela, calibrado como τ_{cluster} , serve de porta ao menos tão bem, e um limiar sobre a taxa agregada nada acrescenta, já que cada sessão mantém uma taxa legítima (Apêndice E). O gatilho sinaliza, assim, uma janela mais movimentada que o tráfego normal, e o teste de enriquecimento da Seção III-H fornece o discriminador. Os pesos ordenam a cadeia de evidência e mantêm a proximidade de rede como evidência auxiliar: um conjunto sustentado *apenas* por ela precisa de três vezes mais pares ligados para alcançar um dado Ω que um conjunto ligado por TLS.

G. Formulação Simbólica

O raciocínio é simbólico em dois estágios (Listagem 1). O SWRL enuncia cada sub-relação *relatedBy* como uma regra Horn sobre os predicados que os extratores de evidência produzem; as numéricas, como distância DTW e similaridade de cosseno de carga útil, entram como comparação embutida contra seu limiar. Em execução, as regras baseadas em igualdade são avaliadas pelo tamanho das classes, sem materializar arestas de par, e a agregação, que o SWRL não expressa por não somar, é uma consulta SPARQL que lê os pesos das anotações *coordinationWeight* da ontologia.

H. Cadeia de Evidência e Escopo de Mitigação Derivado

Quando a regra dispara, o motor emite a regra satisfeita, as instâncias envolvidas, a decomposição de $\Omega(S)$ por sub-relação e o escopo de mitigação derivado. Exportamos isso como JSON-LD e como STIX 2.1, um *indicator* mais um *course-of-action* ligados por *mitigates*, para ingestão por SIEM e SOAR.

Como o escopo é escolhido decide se o veredicto é útil ou prejudicial, e a escolha por frequência falha. A impressão digital modal do agrupamento seleciona aquilo que é comum, e em um serviço sob ataque o que é comum é a população legítima. Contra uma *botnet* espalhada por várias pilhas TLS, cada pilha do atacante é menor que a cabeça da distribuição benigna, de modo que o valor modal é uma impressão digital *legítima* e o filtro resultante bloqueia usuários e nenhum atacante (Seção V-D).

Selecionamos, portanto, o discriminador por **enriquecimento**. Seja $c(f)$ o número de origens do agrupamento que disparou que apresentam a impressão digital f , $n = \sum_f c(f)$, e $b(f)$ a prevalência de f , somada a $1/N$, entre os N pares origem-impressão digital de um perfil de tráfego normal mantido pelo operador fora dos episódios de ataque. O escopo admite todo f que seja enriquecido, $c(f)/n \geq \rho b(f)$, e improvável sob o fundo, $\Pr[X \geq c(f)] < \lambda_e/|F|$ para $X \sim \text{Bin}(n, b(f))$, em que o divisor de Bonferroni $|F|$ conta as impressões digitais do perfil e do agrupamento. O resultado, um *conjunto* de impressões digitais, cobre uma *botnet* fragmentada. Frotas de clientes legítimos que ligam

juntas quebram a independência do binomial no tráfego de produção (Apêndice E), de modo que o nível λ_e é calibrado por *endpoint* e como τ_{cluster} é: o maior valor até 0,01 em que o escopo nomeia um filtro em no máximo 1% das janelas livres de ataque. Usamos $\rho = 3$; no tráfego gerado, em que cada sessão tem origem própria, λ_e fica em 0,01.

O fundo precisa vir de fora do episódio de ataque, porque a campanha se estende por toda a janela e, de outro modo, daria a todo candidato enriquecimento igual a um. Nenhum rótulo está envolvido: o perfil é o que um defensor vê em operação normal. Um adversário que se esconda dentro de uma impressão digital benigna popular não está, portanto, enriquecido, de modo que o *framework* recusa o escopo e reporta que não existe discriminador.

IV. METODOLOGIA DE AVALIAÇÃO

Esta seção detalha a metodologia de avaliação. Cada fonte de tráfego responde a uma pergunta. Um gerador calibrado sobre sessões benignas do CICIDS2017 e sobre JA4 medidos em uma CDN de produção carrega as campanhas controladas da avaliação principal, capturas de laboratório testam ataques convencionais e o sistema publicado mais próximo, e oito dias de tráfego dessa CDN testam os falsos alarmes da regra e, com uma *botnet* injetada, sua detecção. Em seguida apresentamos as linhas de base, as configurações de ablação e as métricas.

A. Cenários e Conjuntos de Dados

A hipótese central tem duas partes: a representação entre sessões ganha da detecção por sessão à medida que o *grau de distribuição* K da campanha cresce, e o caminho simbólico converte essa estrutura em uma decisão auditável e de baixo colateral, de modo que a avaliação é parametrizada por K . O **Cenário A** ($K = 1$), a inundação clássica de origem única, é tratado por detectores volumétricos e degenerado para a área sob a curva ROC (AUC) por sessão. O **Cenário B** ($10 \leq K \leq 100$) modela *botnets* pequenas cujas origens permanecem, cada uma, dentro do próprio limite de taxa, de modo que a proximidade de rede é parcial e os sinais de peso alto precisam sustentar a detecção. O **Cenário C** ($K \geq 1000$) espalha a campanha por centenas de ASNs e prefixos, deixando sinal por sessão desprezível e uma *relatedByNetworkProximity* quase vazia; é aqui que a contribuição precisa se sustentar. Reportamos B ($K = 50$) e C ($K = 1000$).

Avaliação primária: tráfego sintético calibrado. Um gerador produz campanhas distribuídas de Slow HTTP DoS, a família da Seção III-B: sessões sustentadas de baixa taxa contra um único *endpoint*, com verdade de referência de coordenação conhecida, parametrizadas por K , pela fração de origens que compartilham assinatura TLS e identidade, pela dispersão de IP/ASN e pela janela de tempo.

Dois parâmetros desse gerador decidem se o cenário se parece com produção: a popularidade de impressões digitais benignas, que medimos, e a composição da *botnet*, que nenhuma medição publicada fixa e por isso varremos. O primeiro é modelado como uma curva de Zipf de expoente α : populações reais são concentradas, já que um navegador

atualizado em uma dada plataforma emite essencialmente um único JA4 [19]. Calibramos essa curva contra 6,33M de requisições TLS registradas em um ponto de presença de borda em produção da Azion Technologies¹: 495 impressões digitais distintas, a mais comum respondendo por 38,4% das requisições e as dez primeiras por 93,8%. A curva medida é delimitada por $\alpha = 1,5$ e $\alpha = 2,0$. Tomamos $\alpha = 1,5$ como canônico e varremos a faixa. Quanto à composição da *botnet*, *botnets* reais abrangem classes de dispositivo como roteadores, câmeras IP e DVRs [21], e portanto pilhas TLS, de modo que distribuimos 90% da campanha uniformemente por M pilhas, a escolha conservadora para um dado M , e o restante por impressões digitais únicas, e tomamos $M = 25$ como canônico. Um modo *adversarial* permite que a *botnet* adote as impressões digitais benignas mais comuns, como faria um bot que personifica navegador, e marca a fronteira do modelo de ameaça. O Apêndice B relata a medição e suas ressalvas.

As distribuições legítimas são calibradas contra as ~ 322 mil sessões benignas do CICIDS2017 e verificadas por testes de Kolmogorov–Smirnov: $D = 0,003$ para duração e $D = 0,002$ para contagem de requisições, ambos com $p > 0,8$, de modo que as sessões benignas não são mais fáceis que as do CICIDS2017. Um modo *furtivo* sorteia as sessões do atacante das mesmas distribuições do tráfego benigno, de modo que a campanha só se revela pela estrutura entre sessões.

Capturas de laboratório. CICIDS2017 [22] (captura de quarta-feira: Slowloris, Slowhttptest, HULK, GoldenEye) e CIC-IoT2023 [23] (DDoS Slowloris e HTTP Flood), este último o conjunto sobre o qual o KLAGÉ reporta $F_1 = 84,1\%$ para DDoS Slowloris, passam pelo mesmo *pipeline* de extração (PCAP $\rightarrow$ JA4 + fluxos $\rightarrow$ sessões $\rightarrow$ grafo). **Tráfego de produção.** Oito dias de tráfego da CDN da Azion, como contagens de origens distintas, conexões e pares no mesmo /24 por impressão digital e janela de cinco minutos (Apêndice E).

B. Linhas de Base, Configurações e Métricas

Cada configuração da ablação é executada com $n = 30$ sementes distintas, produzindo intervalos por *bootstrap* e testes pareados. Todas as configurações consomem os mesmos atributos de tráfego, de modo que a ablação separa *representação* com a disponibilidade de dados fixa. τ_{cluster} é fixado por cenário no percentil 99 de Ω sobre agrupamentos legítimos, e λ_e de modo que o escopo nomeie um filtro em no máximo 1% deles.

A linha de base por sessão é deliberadamente **forte**: uma Random Forest (RF) sobre todos os oito a nove atributos de fluxo disponíveis (contagem e duração de requisições, somas de bytes e pacotes em ambos os sentidos, média e desvio padrão do intervalo entre requisições). Para que o resultado negativo não dependa de uma única classe de hipóteses, repetimo-lo com *gradient boosting* por histograma, um *perceptron* multicamadas e regressão logística sobre os mesmos atributos. Reimplementamos também três linhas de

¹Medido em 22 de agosto de 2026 a partir de um *log* de acesso que a plataforma já coleta. O extrato guarda apenas impressões digitais de software cliente e suas frequências, sem endereço, *host*, URI, cabeçalho ou localidade.

Tabela II
ROC AUC POR SESSÃO, CENÁRIO SINTÉTICO REALISTA.

Configuração	$K = 50$	$K = 1000$
(a) ML por sessão (forte)	0,498 [47–53]	0,503 [50–51]
(b) ontologia, sem <code>relatedBy</code>	0,500 [47–53]	0,502 [49–51]
(c) só <code>NetworkProximity</code>	0,499 [46–53]	0,659 [65–67]
(d) repr. entre sessões	0,927 [92–93]	0,982 [98–98]
<i>(a) e (d) por família de classificador (estimativas pontuais)</i>		
<i>gradient boosting</i>	0,502 / 0,921	0,501 / 0,990
<i>perceptron</i> multicamadas	0,471 / 0,235 [†]	0,500 / 0,803
regressão logística	0,488 / 0,873	0,495 / 0,799
PCA sobre estatística de fluxo [10]	0,518	0,509
PCA e k -médias sobre matriz de sessão [9]	0,499	0,495
Supervisionado sobre atributos de sessão [5]	0,499	0,503

$\alpha = 1,5$, $M = 25$, $n = 30$ sementes, IC 95%, usuários legítimos no serviço atacado. O caminho simbólico está na Tabela III. [†] Abaixo do acaso, ver texto.

base acadêmicas: perfilamento por PCA [10], PCA seguido de agrupamento por k -médias sobre uma matriz comportamental [9] e RF/SVM supervisionados sobre atributos de sessão [5]. Comparamos contra os números publicados do KLAGÉ no mesmo conjunto e ataque. As quatro configurações de ablação são: **(a)** linha de base de aprendizado de máquina sem ontologia; **(b)** ontologia *sem* sub-relação `relatedBy`, com sessões como nós isolados; **(c)** ontologia *apenas* com `relatedByNetworkProximity`, emulando um detector ingênuo de ASN/prefixo; e **(d)** a representação completa entre sessões sobre as três sub-relações observáveis no tráfego avaliado. Assim (d)–(a) é a contribuição total, (d)–(b) o ganho de representar estrutura entre sessões, e (d)–(c) o ganho dos sinais de peso alto sobre a proximidade de rede.

A configuração (d) consome a evidência entre sessões como *atributos*: a fração do agrupamento que compartilha um mesmo JA4 ou /24, mais seu tamanho. Esse substituto em nível de atributo para a família `relatedBy` mantém todas as configurações iguais em dados e classificador.

Além das métricas usuais de classificação, reportamos **dano colateral**: a fração de tráfego legítimo que cai dentro do escopo derivado do veredicto. Trata-se da taxa de falsos positivos do filtro que um operador implantaria, que pode diferir muito da do detector (Seção V-D). As cadeias de evidência são avaliadas quanto a *completude* (enumeram toda sessão correlacionada e toda sub-relação ativada?) e *acionabilidade* (o escopo derivado é coerente com o discriminador do agrupamento?).

V. RESULTADOS

Os resultados seguem as afirmações que sustentam: a ablação sob campanhas furtivas distribuídas, a regra como detector em tráfego gerado e de produção, as capturas de laboratório e o sistema publicado mais próximo, quanto custa agir sobre o veredicto em colateral e tempo de execução, e a significância.

A. Ablação em Campanhas Furtivas Distribuídas

A Tabela II reporta a AUC por sessão em campanhas furtivas distribuídas cujos usuários legítimos acessam o *mesmo endpoint* e porta do ataque, de modo que nem volume de

Tabela III
O ESCOPO POR ENRIQUECIMENTO DO AGRUPAMENTO DE MAIOR Ω COMO DETECTOR.

Cenário	Regra, sem rótulos			Aprendido, revoc. @ TFP= 0	
	Revoc.	TFP	F_1	(d)	+ perfil
Monolítica ($M=1$)	89,8%	0,00%	0,946	91,7%	85,9%
$M=5$	90,0%	0,00%	0,948	88,6%	91,7%
$M=25$	90,3%	0,00%	0,949	36,4%	87,4%
$M=100$	38,6%	0,00%	0,556	17,6%	86,9%
$M=25$, adversarial	30,4%	3,78%	0,452	7,8%	6,6%

Os modelos aprendidos treinam com rótulos da campanha que pontuam; o segundo também lê o perfil da regra. $K = 1000$, $n = 15$ sementes. TFP: taxa de falsos positivos.

fluxo nem porta de destino separam as classes. A detecção por sessão (a) com o conjunto completo de atributos de fluxo, as três linhas de base acadêmicas e a configuração (b), que acrescenta atributos ontológicos por sessão mas nenhuma relação entre sessões, ficam todas no acaso ($AUC \approx 0,50$), já que cada sessão do atacante é sorteada das distribuições benignas por construção, e (a) permanece ali em toda família de classificador (0,471–0,503), de modo que o colapso está na representação. A representação entre sessões (d) alcança 0,93–0,98, e (c), restrita à proximidade de rede, apenas 0,50–0,66, porque a *botnet* está dispersa.

É na configuração (d) que a escolha do modelo começa a importar. Fragmentar a *botnet* em 25 pilhas torna a evidência entre sessões *não monotônica* no rótulo: um atacante compartilha impressão digital com algumas dezenas de pares, um cliente legítimo da cabeça benigna com centenas. Ensembles de árvores recortam a faixa intermediária (0,98–0,99 em $K = 1000$, 0,92–0,93 em $K = 50$), a regressão logística cai para 0,80 e 0,87, e o *perceptron* inverte em $K = 50$ ($AUC = 0,235$), tendo aprendido que uma impressão digital amplamente compartilhada indica tráfego benigno. A regra da Seção III-H dispensa amostra rotulada para inferir a linha de base benigna, pois lê um perfil explícito de tráfego normal.

Que (b) também fique no acaso mostra que atributos por sessão não bastam: é a *relação explícita entre sessões* que sustenta a detecção. Os sete agrupamentos de ataque das duas capturas de laboratório, seis ataques e a classe DoS-Other do CICIDS2017, vêm de uma a sete origens em um único /24, inundações ao alcance de um limite por prefixo; a Listagem 2 (Apêndice D) traz a cadeia de evidência de uma campanha canônica, e um estudo com analistas humanos é trabalho futuro.

B. A Própria Regra como Detector

Todo número até aqui veio de um classificador, o que nada diz sobre a camada simbólica, e por isso avaliamos a regra diretamente: as sessões que casam com o escopo da Seção III-H são o conjunto sinalizado, sem treino de modelo e sem rótulo, e a decisão chega com sua derivação. Como a AUC ordena e a regra decide, forçamos o classificador ao ponto de operação da regra (Tabela III).

Contra uma *botnet* monolítica ou pouco fragmentada, o modelo aprendido é competitivo em zero falsos positivos (91,7% e 88,6% de revocação contra 89,8% e 90,0%). Em 25 pilhas

a regra abre vantagem, 90,3% contra 36,4%, dianteira que mantém sobre um modelo autorizado a 1% de TFP (66,8%), embora esse modelo ordene bem (AUC 0,979): seus escores se sobrepõem ao tráfego benigno na cauda. Esse modelo não lê perfil algum de tráfego normal, e a regra lê. Dado o perfil como dois atributos por sessão, a prevalência da impressão digital da sessão e seu enriquecimento no agrupamento, o modelo recupera 87,4% em 25 pilhas e 86,9% em cem, onde pilhas pequenas demais para um perfil de mil sessões certificar prendem a regra em 38,6% (Seção V-D). Ele treina com rótulos da campanha que pontua, que nenhum operador tem durante um ataque; a regra o iguala até 25 pilhas sem nenhum. Na linha adversarial a própria regra incorre em uma taxa de falsos positivos de 3,78%, e o modelo alcança 23,4% uma vez autorizado a 1%.

A Tabela III toma o agrupamento de maior Ω como disparado, sem limiar. Rodada por janela de cinco minutos, sobre chegadas benignas que espalhamos ao longo de uma hora (Tabela V), a condição $\Omega(S) \geq \tau_{\text{cluster}}$ sozinha dispara em 78 a 86% das janelas de ataque e em 0,6% das limpas, mas também em 80 a 100% dos *flash crowds*, e exigir que o teste de enriquecimento nomeie uma impressão digital elimina todo falso alarme e mantém a detecção, sem colateral.

O tráfego de produção (Tabela VI) quebra duas suposições embutidas no gerador. Um cliente abre muitas conexões, e por isso, contado em conexões, o escopo nomeia um filtro em 60,1% das janelas limpas, 26,9% em origens; e frotas de clientes legítimos ligam juntas, e por isso λ_e é calibrado nos dias anteriores, o que leva a regra a 0,2% das janelas limpas. Seu gatilho age como um limiar de volume. Um limiar no percentil 99 sobre origens distintas dispara nas mesmas janelas em 86 a 99,6% dos casos e, como porta, reduz os falsos alarmes à metade sem perda de detecção (6 contra 14 janelas limpas). O escopo separa ataque de pico. Em pilhas da *botnet* que clientes reais também apresentam, o enriquecimento bloqueia 20,2% e 61,6% de 100 e 1000 atacantes por janela, onde um filtro de impressões digitais inéditas não bloqueia nenhum, e dispara em 3,9% dos *flash crowds* de 100 usuários, onde um z -score dispara em 64,5%. Unido ao filtro de inéditas atrás da porta de origens, dispara em 0,1% das janelas limpas e bloqueia 38,4% e 77,7% dessas *botnets* em pilhas novas, mas seus falsos alarmes bloqueiam uma mediana de 29,9% dos clientes da janela. Escolhemos esses dois refinamentos nos mesmos dias de teste, nos quais valem em cada um dos cinco; dias novos precisam confirmá-los (Apêndice E).

C. Capturas de Laboratório e Comparação com o KLAGÉ

Em capturas de laboratório, o quadro por sessão muda (Tabela IV). Uma linha de base *enxuta* por sessão (três atributos) desaba para $F_1 = 0,179$, mas uma *forte* (oito atributos de fluxo) alcança 0,900, porque o Slowloris real do CIC-IoT2023, ao contrário das nossas campanhas furtivas, deixa assinatura de fluxo por sessão, e o *framework* entre sessões alcança 0,911, de modo que a coordenação não é necessária nesse ataque. A comparação com o KLAGÉ é favorável, mas *não controlada*:

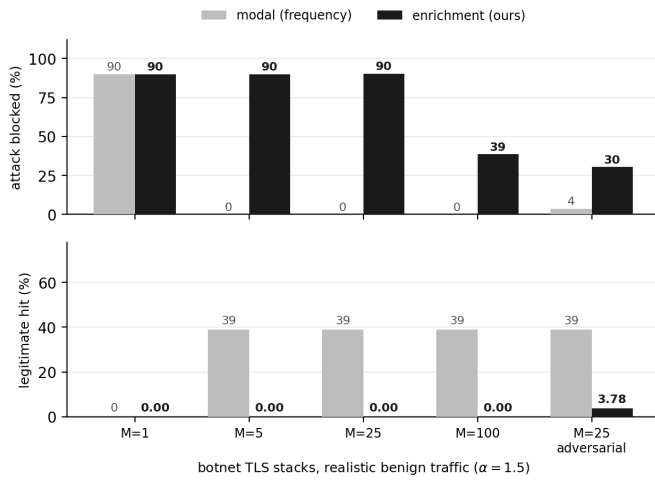


Fig. 3. Derivação do escopo: frequência contra enriquecimento ($\alpha = 1,5$, $n = 15$).

nostra linha de base forte também supera o 0,841 publicado, de modo que a margem não é da representação, e o código liberado, que parte de um grafo pré-construído de construção não publicada e não distribui pesos, não admite reexecução controlada. Os conjuntos públicos de DDoS contêm apenas ataques com assinatura de fluxo evidente, nenhum no regime furtivo distribuído (Fig. 4, Apêndice C).

D. Dano Colateral em Tráfego Legítimo

A mitigação só faz sentido como par, o que o escopo derivado bloqueia e quanto isso custa, que a Fig. 3 reporta para as regras por frequência e por enriquecimento sobre $n = 15$ campanhas por configuração.

Para uma *botnet* monolítica as duas concordam: 89,8% das sessões do atacante bloqueadas sem colateral observado, onde um limite global de taxa no *endpoint* desconecta todo usuário legítimo; a regra por frequência foi validada nesse regime, que não é representativo. A partir de cinco pilhas, a impressão digital modal do agrupamento passa a ser uma *legítima* e a regra se inverte: 0,0% do ataque bloqueado e 39,0% do tráfego legítimo atingido, uma perda líquida que impõe o custo da mitigação sem o benefício dela. Uma população benigna mais concentrada ($\alpha = 2,0$) eleva esse colateral a 61,1%.

O enriquecimento elimina a falha, bloqueando 90,0% e 90,3% do ataque em $M = 5$ e 25 pilhas **sem colateral observado** nas $n = 15$ campanhas, e reproduzindo a regra por frequência onde ela funcionava. Os 10% que sobrevivem são

Tabela IV
DDoS SLOWLORIS NO CIC-IOT2023 (captura de laboratório).

Método	F_1	Prec.	Revoc.	AUC
KLAGE, nível de nó [7]	0,841	-	-	-
(a) ML por sessão, 3 atrib.	0,179	0,691	0,103	0,551
(a') ML por sessão, 8 atrib.	0,900	0,901	0,899	0,987
(d) entre sessões (nosso)	0,911	0,908	0,915	0,982

A captura abrange 143 prefixos /24 distintos; seus agrupamentos de ataque têm sete origens em um só.

a cauda de atacantes com impressões digitais únicas, de modo que a mitigação com escopo troca completude por precisão. Em $M = 100$ a cobertura cai para 38,6%, ainda sem colateral: uma pilha de cerca de dez sessões em duas mil não se distingue da cauda de um perfil de 1 000 sessões, e agregar ao perfil 30 períodos livres de ataque restaura 89,6%.

Dois condições limitam o resultado. A primeira é a fronteira do modelo de ameaça: quando a *botnet* adota impressões digitais benignas comuns, pouco fica enriquecido e a regra bloqueia 30,4% do ataque a 3,78% de colateral, contra 3,6% e 39,0% da regra por frequência, e com um ρ mais estrito o escopo se recusa a nomear uma impressão digital, o relato correto quando não existe discriminador. A segunda é o perfil de fundo. Deriva moderada é tolerável (perfil com $\alpha = 2,0$ contra episódio com $\alpha = 1,5$: 90,3% de cobertura, sem colateral), enquanto um perfil achatado ou ausente faz toda impressão digital parecer rara e o colateral salta para 77,6%. Um perfil atualizado e amplo é, assim, requisito de implantação: onde ele reprovar em uma verificação de frescor ou de deriva, a mitigação com escopo é suprimida e o veredicto emitido apenas como evidência.

E. Custo e a Escolha de W

Mantidas como classes (Apêndice D), as sub-relações baseadas em igualdade tornam a admissão constante em cerca de $0,37 \mu s$ por sessão e a camada simbólica linear, com 26,4 s para 100 000 sessões contra 52,8 s com arestas de par em 1000: $\Omega(S)$ cresce com o quadrado do agrupamento, e calculá-lo deixou de crescer assim. A AUC de (d) é plana ao longo de uma faixa de $30\times$ em W , de modo que a representação tolera qualquer W que o tráfego permita; a regra em si rodou apenas com $W = 300$ s.

F. Significância Estatística

Testes de Wilcoxon pareados sobre as $n = 30$ execuções, com correção de Bonferroni sobre quatro comparações, tornam (d)–(c) e (d)–(a) significativos em $K = 1000$ ($p_{\text{Bonf}} = 7,5 \times 10^{-9}$, d de Cohen de 13,5 e 22,4). As sementes são sorteios de um mesmo gerador, então os testes mostram uma diferença estável entre sorteios e nada preveem sobre o campo.

VI. DISCUSSÃO E LIMITAÇÕES

Discutimos o particionamento, depois o que limita os resultados e o que o grafo acrescenta (outras limitações no Apêndice C).

Paralelismo e particionamento. A condição (ii), um *endpoint* por S , faz do *endpoint* a chave natural de particionamento: particionar por ele avalia a regra de forma *exata*, sem tráfego entre partições e com estado por partição limitado pela janela. Uma campanha que espalha um mesmo JA4 por muitos *endpoints* acumula, então, pares de menos em cada partição para ultrapassar τ_{cluster} , enquanto particionar por JA4 quebra a condição de *endpoint*. Nenhuma chave isolada preserva as seis sub-relações, e o Apêndice D esboça um desenho em dois níveis.

O ganho é específico de regime. Limiares por IP resolvem inundações de origem única, e um classificador forte por sessão alcança $AUC \geq 0,98$ nos ataques de conjuntos públicos. Só campanhas distribuídas e furtivas precisam do *framework*, que complementa as defesas volumétricas.

Cada avaliação estabelece uma coisa. O gerador mostra o mecanismo sob uma imitação imposta por construção, com as sessões do atacante tirando seus atributos de distribuições benignas reais, de modo que a não separabilidade da Tabela II não é artefato de uma linha de base enfraquecida. O tráfego de produção mede falsos alarmes sobre clientes reais, e a detecção apenas para uma *botnet* injetada, ao longo de oito dias de uma única operadora; onde seu tráfego corresponde ao modelo de ameaça (E1, uma *botnet* de um décimo da janela típica), o nível calibrado prende o enriquecimento em 0,6% dos atacantes, e um perfil que conhece suas frotas, testado em dias reservados, em 6,3%. Nenhuma avaliação cobre uma campanha furtiva capturada.

A representação e o escopo dependem de um discriminador observável de peso alto. Uma varredura de robustez ($n = 10$, no artefato) torna a dependência explícita: à medida que a fração de origens que compartilham a impressão digital TLS cai, a $AUC(d)$ decresce monotonicamente de 1,00 para $\approx 0,74$ sob aleatorização, resíduo do conjunto finito de JA4 benignos, e a convergência de *endpoint* não compensa, já que usuários legítimos também convergem ali. O gatilho de volume sobrevive à perda do JA4, mas o escopo fica então sem discriminador. Ruído temporal e identidades rotacionadas deixam o escopo intacto, já que ele se apoia no JA4; um bot fora do modelo de ameaça que também apresente o JA4 de um navegador o derrota, e o Encrypted Client Hello [24] pode ocultar o JA4.

O que o grafo acrescenta. A configuração (d) exprime a evidência do grafo como atributos, e um modelo linear sobre os mesmos três atributos entre sessões ainda alcança 0,799 contra 0,495 do conjunto por sessão, de modo que o ganho de AUC da Tabela II vem de representar estrutura entre sessões. O OWL não acrescenta nada a esse número, nem ao gatilho, que na escala da janela é volume, e um modelo aprendido que lê o perfil da regra e os rótulos da campanha iguala ou supera a regra (Tabela III). O que o grafo acrescenta é operacional, e mensurável. A ontologia marca o que cada sub-relação de igualdade iguala, seu peso e a unidade em que as classes são contadas, e a consulta que conta as classes da regra é compilada a partir dela: em sessões geradas o SQL compilado reproduz Ω exatamente, rodado no armazém de logs da operadora ele devolve as contagens exportadas de origens e de pares no mesmo /24 em todas as 1 152 janelas de um dia, de modo que nenhum endereço sai do armazém, e um sinal acrescentado à ontologia como quatro triplas chega à consulta sem mudança em código algum. O veredicto, sua decomposição e o escopo (Listagem 2) são exportados como um único pacote STIX 2.1 que o validador da OASIS aceita em modo estrito, de modo que um *playbook* de SOAR recebe um *course-of-action* já parametrizado pelo escopo. O veredicto é *explicável* nesse sentido de derivação inspecionável; se ele

encurta a decisão de um analista permanece não testado.

VII. CONCLUSÃO E TRABALHOS FUTUROS

Modelamos a sessão HTTP como entidade de primeira classe, relacionada a outras sessões por seis sub-propriedades tipadas ponderadas pelo custo de evasão, e dispparamos uma regra SPARQL/SWRL cuja derivação serve de veredicto, cadeia de evidência e escopo de mitigação.

Contra campanhas furtivas geradas de dispositivos comprometidos, a detecção por sessão fica no acaso em quatro classificadores, enquanto atributos entre sessões alcançam ROC AUC 0,93–0,98, e em ataques convencionais de laboratório basta um classificador forte por sessão. Definir o escopo pela propriedade mais comum do agrupamento seleciona uma impressão digital legítima assim que a *botnet* se espalha por várias pilhas TLS, ao passo que um teste binomial de enriquecimento sobre o tráfego normal restaura 90% de cobertura em 25 pilhas sem colateral observado e sem rótulo, e não dispara em nenhum *flash crowd* gerado; um modelo aprendido só o iguala ou supera com o mesmo perfil e os rótulos da campanha. No tráfego de uma CDN o gatilho se reduz a uma contagem de origens distintas, e o teste calibrado ainda nomeia pilhas compartilhadas com clientes reais enquanto ignora a maior parte dos *flash crowds*, embora, onde o modelo de ameaça vale, certifique poucas, caso que um perfil que conhece as frotas do *endpoint* eleva de 0,7% para 6,3%; modelos de frota mais ricos, ataques sobre HTTP/2 e uma campanha furtiva capturada vêm a seguir.

AGRADECIMENTO

Agradecemos à Azion Technologies (<https://www.azion.com/>) por autorizar a medição de impressões digitais da Seção IV e as estatísticas agregadas de tráfego do Apêndice E, exportadas sem endereços, portas ou URIs.

REFERÊNCIAS

- [1] MITRE Corporation, “CVE-2023-44487: HTTP/2 rapid reset attack,” National Vulnerability Database, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [2] Google Cloud, “How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack,” Google Cloud Blog, 2023. [Online]. Available: <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>
- [3] Cloudflare, “Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report,” Cloudflare Blog, 2025. [Online]. Available: <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, “Slow DoS attacks: Definition and categorisation,” *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.
- [5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, “An approach to application-layer DoS detection,” *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.
- [6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, “A survey and meta-analysis of application-layer distributed denial-of-service attack,” *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.
- [7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, “Enhancing network security using knowledge graphs and large language models for explainable threat detection,” *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.

- [8] J. Zhang, H. Zhang, C. Xia, and L. Sun, “Graph-BERT: Only attention is needed for learning graph representations,” *arXiv preprint arXiv:2001.05140*, 2020.
- [9] R. Bharathi and R. Sukanesh, “A PCA based framework for detection of application layer DDoS attacks,” *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.
- [10] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., “Autonomous profile-based anomaly detection system using principal component analysis and flow analysis,” *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.
- [11] L. Sadlek, M. Husák, and P. Čeleda, “Identification of device dependencies using link prediction,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.
- [12] X. Wang and R. Stadler, “IT intrusion detection using statistical learning and testbed measurements,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.
- [13] A. Martinetti, “Advancing threat intelligence: JA4 fingerprints and inter-request signals,” Cloudflare Blog, Aug. 2024. [Online]. Available: <https://blog.cloudflare.com/ja4-signals/>
- [14] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.
- [15] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, “Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions,” in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.
- [16] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, “Recent progress of using knowledge graph for cybersecurity,” *Electronics*, vol. 11, no. 15, p. 2287, 2022.
- [17] N. Tripathi and N. Hubballi, “Application layer denial-of-service attacks and defense mechanisms: A survey,” *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.
- [18] W3C OWL Working Group, “OWL 2 web ontology language profiles, 2nd ed.” W3C Recommendation, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-profiles/>
- [19] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, “JA4+ network fingerprinting,” FoxIO, 2023. [Online]. Available: <https://blog.foxio.io/ja4+-network-fingerprinting>
- [20] OASIS, “STIX version 2.1,” OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [21] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.
- [22] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [23] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” *Sensors*, vol. 23, no. 13, p. 5941, 2023.
- [24] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS encrypted client hello,” IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-tls-esni/>
- [25] M. Shafi, A. H. Lashkari, V. Rodriguez, and R. Nevo, “Toward generating a new cloud-based distributed denial of service (DDoS) dataset and cloud intrusion traffic characterization,” *Information*, vol. 15, no. 4, p. 195, 2024.

APÊNDICE A

CONSTRUÇÃO EM TEMPO DE EXECUÇÃO E INSTANCIAÇÃO DAS SUB-RELAÇÕES

Algoritmo 1 Construção do grafo de conhecimento em tempo de execução

Requer: fluxo de requisições $\mathcal{R}$, ontologia $\mathcal{O}$, janela W
Garante: grafo de conhecimento KG persistente ao longo de W

```

1:  $KG \leftarrow \emptyset$ 
2: for cada requisição  $r \in \mathcal{R}$  do
3:    $s, i, e \leftarrow \text{RESOLVESSÃO/IDENTIDADE/ENDPOINT}(r)$ 
4:    $KG.\text{add}(s, i, e); KG.\text{link}(s, \text{hasIdentity}, i)$ 
5:    $KG.\text{link}(s, \text{targets}, e)$ 
6:   for cada  $s' \in S_W$  ativa,  $s' \neq s$  do
7:     for cada sub-relação  $i \in \mathcal{R}_{\text{rel}}$  do
8:       if  $\text{VALE}_i(s, s')$  then
9:          $KG.\text{link}(s, \text{relatedBy}_i, s')$ 
10:      end if
11:    end for
12:  end for
13:   $KG.\text{purgeOutside}(W)$ 
14: end for
15: return  $KG$ 

```

O Algoritmo 1 constrói o grafo sobre a janela deslizante. Ele enumera pares por clareza: as relações baseadas em igualdade são mantidas como contagens de classe (Seção III-E), e para as demais os procedimentos a seguir decidem, para cada par candidato (s_a, s_b) , se a aresta é instanciada.

TLSFingerprint. Casamento em dois estágios: igualdade exata do JA4 completo ou, na falta dela, variantes próximas (mesmo prefixo de transporte/versão TLS/ALPN, com no máximo um símbolo de diferença nos blocos ordenados de cifras ou extensões), instanciadas com anotação $ja4_distance = 1$. Isso absorve a deriva de versão dentro de uma mesma biblioteca cliente sem admitir casamentos espúrios entre pilhas distintas. Custo $O(1)$ por par.

ReusedIdentity. Instanciada em qualquer *cookie*, token ou nome de usuário compartilhado, com JWTs comparados pela *claim* sub e *cookies* e nomes de usuário normalizados (corte de espaços, caixa baixa). Custo $O(1)$ amortizado com índice invertido.

TemporalPattern. Com $\Delta(s)$ os intervalos entre chegadas de uma sessão de ao menos três requisições, a aresta vale quando $\text{DTW}(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|) \leq \tau_{\text{DTW}}$. O FastDTW sob uma banda de Sakoe–Chiba torna o custo linear por par, e o *hashing* sensível à localidade sobre vetores-resumo evita a comparação de todos os pares.

PayloadSignature. Sobre a média e o desvio do tamanho de corpo e *hashes* do User-Agent e do Content-Type dominantes, a aresta vale quando a similaridade de cosseno excede τ_{payload} .

EndpointConvergence. Instanciada quando ambas as sessões convergem no mesmo *endpoint*, sob normali-

```

# SWRL (Horn): instancia uma sub-relacao
ApplicationSession(?a) ^ ApplicationSession(?b) ^
differentFrom(?a,?b) ^
tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
-> relatedByTLSFingerprint(?a,?b)

# SPARQL: agregacao ponderada pelo tamanho das
# classes, contado em origens distintas
SELECT ?e (SUM(?w * ?n * (?n - 1) / 2) AS ?omega)
WHERE {
  { SELECT ?e ?c (COUNT(DISTINCT ?o) AS ?n)
    WHERE { ?s kg:targets ?e ; kg:inClass ?c ;
            kg:originatesFrom ?o . }
    GROUP BY ?e ?c }
  ?c kg:ofRelation ?rel .
  ?rel rdfs:subPropertyOf kg:relatedTo ;
    kg:coordinationWeight ?w .
  ?e kg:tauCluster ?tau . }
GROUP BY ?e ?tau
HAVING (SUM(?w * ?n * (?n - 1) / 2) >= ?tau)

```

Listagem 1. Veredicto como derivação: uma regra de Horn e a agregação SPARQL.

zação de padrão de caminho (/api/users/12345 → /api/users/{id}) por padrão; um casamento adicional de caminho exato anota a aresta com *exact = true*. Custo $O(1)$ com índice em árvore de prefixos.

NetworkProximity. Instanciada em prefixo IPv4 /24 (ou IPv6 /48) compartilhado, ou em ASN compartilhado, ou em ambos; quando ambos valem, a aresta é anotada com *strong = true*. A resolução de ASN usa tabelas BGP correntes. Custo $O(1)$ com índice invertido de prefixos.

APÊNDICE B CALIBRAÇÃO DOS PESOS

A calibração empírica depende criticamente do realismo do tráfego. Em conjuntos de laboratório, com algumas dezenas de impressões digitais JA4 distintas, a otimização chega a inverter o sinal do indicador TLS, porque sessões benignas compartilham impressões digitais mais do que campanhas parcialmente coordenadas, artefato de bancada oriundo da baixa diversidade de JA4.

No cenário realista, usuários acessam o serviço atacado com impressões digitais tiradas de um conjunto de 2 000, cuja forma de Zipf as 495 medidas em um ponto de presença fixam; o conjunto excede as 76 a 818 que cada *endpoint* de produção do Apêndice E mostra ao longo de seus dias de calibração, de modo que a cauda benigna é mais longa que a observada. Calibramos maximizando a ROC AUC por sessão entre ataque e benigno sobre o escore $w_{\text{tls}} z(\text{ja4}) + w_{\text{ep}} z(\text{conv. endpoint}) + w_{\text{net}} z(\text{prox. rede})$ com atributos padronizados, sobre a grade $\{0,3 \dots 1,0\}^3$ (125 combinações, 60 cenários, 91 500 sessões). O resultado corrobora a ordenação proposta: o melhor vetor é $(w_{\text{tls}}=1,0, w_{\text{ep}}=0,3, w_{\text{net}}=0,3)$, e a impressão digital TLS é o único sinal individualmente discriminativo (AUC isolada = 0,93, contra 0,50 da convergência de *endpoint* e 0,58 da proximidade de rede). Os pesos da Fig. 1 (1,0, 0,6, 0,3) atingem a mesma AUC = 0,943 ótima e são insensíveis a perturbação de $\pm 20\%$. A calibração valida, portanto, a *ordenação*; no regime puro de mesmo serviço os pesos médio e baixo não são separadamente identificáveis, já que ambos ficam próximos do

acaso. Seus valores absolutos permanecem em aberto: a regra por janela detecta igual com pesos uniformes (Apêndice E), de modo que eles ordenam a evidência mais do que conduzem a detecção.

Realismo do Gerador

Duas ressalvas se aplicam à medição: o *log* não carrega identificador de conexão, então a ponderação é por requisição, o que, se enviesa, *superestima* a concentração, e a amostra é de um ponto de presença em uma janela. A bancada do CICIDS2017 [22] é ainda mais concentrada (cabeça de 52,7%). A cabeça medida casa com $\alpha = 1,5$ (38,9% contra 38,4%) e as dez primeiras com $\alpha = 2,0$ (94,2% contra 93,8%), de modo que a varredura a delimita.

APÊNDICE C LIMITAÇÕES ADICIONAIS

Instrumentação de sessão e identidade. A abordagem pressupõe que sessões, identidades e impressões digitais TLS possam ser extraídas dos eventos de tráfego; onde essa instrumentação for parcial ou ruidosa, o desempenho cai. Contar origens pelo endereço de origem subconta usuários atrás de um endereço de CGN e sobreconta clientes que rotacionam endereços de privacidade IPv6, para os quais o /64 é a unidade natural.

Custo de manutenção do grafo. Os números simbólicos do Apêndice D são um limite superior, pela razão ali exposta, e a rodada de produção do Apêndice E é *offline*, sobre contagens agregadas por *endpoint*, de modo que uma implantação real em CDN ainda exige o particionamento da Seção VI, que não implementamos.

Cobertura de protocolo. Ataques sobre HTTP/2 e outros protocolos de aplicação (DNS, gRPC) exigem sub-relações além da família Slow HTTP DoS sobre HTTP/1.1.

Cobertura de sub-relações. O $\Omega(S)$ avaliado instancia as três sub-relações que o gerador e as capturas públicas expõem; reaproveitamento de identidade, padrão temporal e assinatura de carga útil estão especificados (Apêndice A) mas não são exercitados, e seus pesos não foram testados.

Amplitude de conjuntos de dados. A validação em laboratório cobre um conjunto e um ataque na comparação direta, mais seis ataques entre CICIDS2017 e CIC-IoT2023 na análise de regime; RT-IoT2022, CIC-DDoS2019 e uma campanha furtiva capturada permanecem trabalho futuro. *Benchmarks* mais novos mantêm a lacuna: a representação inadequada da camada de aplicação é apontada como deficiência do BCCC-cPacket-Cloud-DDoS-2024 [25], cujos 17 cenários de DDoS são todos baseados em TCP, e não encontramos captura independente do regime furtivo de camada 7.

Validação da explicação. As cadeias de evidência dos sete agrupamentos de laboratório passam nas verificações automáticas de completude e acionabilidade (7/7) quando contadas em sessões; contados em origens, os cinco do CICIDS2017 têm de uma a três origens, abaixo de k_{min} , e os dois do CIC-IoT2023 têm sete; nenhum estudo com usuários as testou.

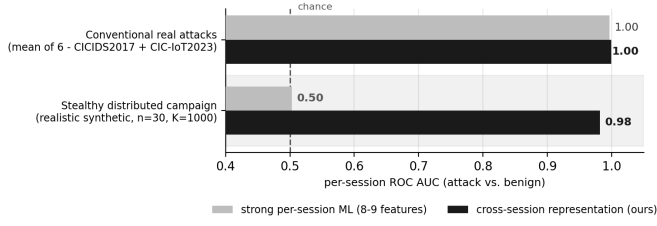


Fig. 4. Onde a evidência entre sessões é necessária.

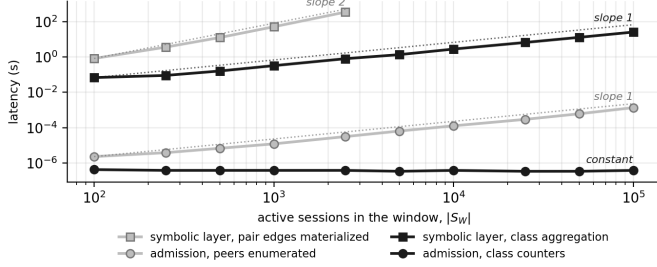


Fig. 5. Custo das duas camadas, com arestas de par e com contagens de classe.

APÊNDICE D

MODELO DE CUSTO E SENSIBILIDADE À JANELA

A admissão acontece por requisição, enquanto a materialização e a agregação de Ω rodam uma vez por janela, então cronometramos as duas camadas separadamente, sobre uma janela sintética na mistura realista (30% das sessões em uma campanha compartilhando um JA4 de *botnet*, JA4 benignos de um conjunto de 2000, oito *endpoints*, /24s dispersos), com medianas de três repetições em um núcleo. Cada camada roda de dois modos: com arestas de par, como as regras estão escritas, e com contagens de classe para as sub-relações baseadas em igualdade. Os dois dão o mesmo $\Omega(S)$ para todo *endpoint*, com diferença de até 7×10^{-12} . Este é um modelo de custo do algoritmo: a camada simbólica roda sobre *rdflib* em memória no lugar do Jena/TDB2, de modo que seus números são um limite superior, e contar origens acrescenta uma consulta a tabela *hash* por admissão.

Com enumeração de pares, a latência mediana de admissão cresce de $2,3 \mu s$ em $|S_W| = 100$ para $127 \mu s$ em $|S_W| = 10000$, acompanhando a contagem de pares candidatos (de 148 a 6495 arestas por admissão) a 15–21 ns por par. Com contadores de classe, ela fica entre $0,33$ e $0,42 \mu s$ de 100 a 100 000 sessões (Fig. 5, onde as linhas pontilhadas são inclinações de referência).

Materializar arestas de par custa $0,84$ s em $|S_W| = 100$ e $52,8$ s em 1000, entre 198 e $309 \mu s$ por aresta RDF, de modo que esse caminho é linear em arestas e quadrático em sessões. A agregação por classes materializa uma tripla de pertinência por sessão e sub-relação e calcula $\Omega(S)$ com a consulta da Listagem 1 em $0,33$ s para 1000 sessões, 161 vezes mais rápido, e em $26,4$ s para 100 000. O termo quadrático vive, assim, no valor de $\Omega(S)$, que conta pares, e nas arestas de par das sub-relações não transitivas, cujos candidatos os

```
"@type": "kg:CoordinatedHTTPFlood",
"kg:clusterSize": 1991, "kg:coordinationScore": 1303422.8,
"kg:activatedSubRelations": [
  {"@type": "kg:relatedByTLSPFingerprint",
   "kg:coordinationWeight": 1.0, "kg:linkedPairs": 114710,
   "kg:weightedContribution": 114710.0},
  {"@type": "kg:relatedByEndpointConvergence",
   "kg:coordinationWeight": 0.6, "kg:linkedPairs": 1981045,
   "kg:weightedContribution": 1188627.0},
  {"@type": "kg:relatedByNetworkProximity",
   "kg:coordinationWeight": 0.3, "kg:linkedPairs": 286,
   "kg:weightedContribution": 85.8}],
"kg:derivedMitigationScope": {
  "kg:endpoint": "10.0.0.1:443",
  "kg:tlsJa4": ["t13d1516h2_synth_0001_00", ...]}
```

Listagem 2. Cadeia de evidência de uma campanha canônica ($M = 25$, $K = 1000$), contada em origens; o escopo lista 25 impressões digitais, resumido.

índices restringem. A cadeia de evidência precisa apenas das contagens de pares (Listagem 2), que as classes fornecem.

W entra apenas pela atribuição de agrupamentos de detecção, de modo que uma varredura de $W = 60$ a 1800 s recomputa os atributos entre sessões sobre os mesmos cenários ($K = 1000$, $n = 10$): a AUC de (d) fica em $0,976$ – $0,978$ e a de (c) em $0,663$ – $0,664$, já que o atributo discriminativo é a *fração* de um agrupamento que compartilha um JA4. Os cenários miram um único *endpoint*, e W precisa deixar um agrupamento se formar (≈ 132 sessões em $W = 60$ s).

Particionamento em Escala de CDN

O desenho que o particionamento por *endpoint* sugere, não implementado aqui, é de dois níveis: trabalhadores particionados por *endpoint* mais um esboço global sobre identificadores de peso alto para recuperar campanhas que se espalham por vários *endpoints*. Quantificar a revocação perdida pelo primeiro nível e recuperada pelo segundo é pré-condição para implantação em escala de CDN. Com a contagem por classes as duas camadas ficam lineares na janela e a admissão bem abaixo de um microssegundo; confirmá-lo em escala de CDN é trabalho futuro.

APÊNDICE E

A REGRA POR JANELA

Aqui a regra roda como implantada, por janela de $W = 300$ s e *endpoint*, e nenhum limiar vê ataque ou rótulo. $\tau_{cluster}$ é o 99º percentil de Ω sobre as janelas de 30 execuções livres de ataque, que também formam o perfil; os falsos alarmes são contados em outras 30, a detecção nas campanhas canônicas ($\alpha = 1,5$, $M = 25$) sobre janelas com ao menos $k_{min} = 5$ atacantes, e um *flash crowd* reposiciona 25, 50 ou 100 sessões legítimas de uma terceira execução em uma janela. Espalhamos os inícios benignos por 60 min, já que o gerador os concentra nos primeiros minutos.

Um *flash crowd* acrescenta massa como uma campanha; o teste de enriquecimento distingue os dois porque esses *flash crowds* sorteiam seus usuários da mistura benigna que o perfil descreve, enquanto um surto em um único tipo de cliente fica enriquecido, como mostram as frotas de produção adiante. Com o teste, a regra não dispara em nenhuma janela limpa (limite superior de 95%: 0,8%) nem em nenhum *flash crowd*,

Tabela V
A REGRA POR JANELA DE CINCO MINUTOS, 30 EXECUÇÕES POR LINHA.

Janelas	n_W	$\Omega \geq \tau$	Ω e enriquecimento		
			Dispara	Cob.	Col.
Ataque, $K = 1000$	90	77,8%	77,8%	79,8%	0,0%
Ataque, $K = 50$	35	85,7%	85,7%	75,3%	0,0%
Limpas	360	0,6%	0,0%	–	–
Flash crowd, 25	30	80,0%	0,0%	–	–
Flash crowd, 50	30	100%	0,0%	–	–
Flash crowd, 100	30	100%	0,0%	–	–

Cob.: fatia mediana dos atacantes da janela que o escopo bloqueia. Col.: maior fatia de suas sessões legítimas bloqueada.

Tabela VI
A REGRA EM OITO DIAS DE TRÁFEGO DE PRODUÇÃO.

Endpoint	Orig.	Limpas (%)			Botnet bloqueada (%)		
		Disparos	Colat.	Flash	A=100	1000	1×
E1, beacons de RUM	$> 10^3$	0,1	5,4	0,1	0,0	38,3	67,6
E2, console web	$< 10^2$	0,7	50,2	5,3	0,0	83,6	0,0
E3, API	$< 10^2$	0,1	51,9	8,2	25,7	90,0	0,4
E4, SSO	$< 10^2$	0,0	–	2,2	78,8	90,0	0,9
<i>Todos, porta $\Omega \geq \tau$; pilhas novas / compar.</i>							
Enriquecimento		0,2	49,1	3,9	26,1/20,2	75,5/61,6	17,2/16,5
z-score		2,6	22,8	64,5	66,4/63,9	85,6/84,3	32,6/31,4
JA4 inéditos		0,0	3,3	0,2	28,6/0,0	77,1/0,0	18,4/0,0
Enriq. $\cup$ inéditos		0,3	48,6	4,0	37,5/20,2	77,1/61,6	18,6/16,5
<i>Todos, com porta de origens distintas</i>							
Enriquecimento		0,1	31,4	3,9	26,1/20,2	76,1/62,1	18,4/17,4
Enriq. $\cup$ inéditos		0,1	29,9	4,0	38,4/20,2	77,7/62,1	19,9/17,4

Orig.: origens por janela. Limpas: fração de 5643 janelas livres de ataque em que o escopo nomeia um filtro sob a porta, e a fração mediana de seus clientes que ele então bloqueia. Flash: a mesma fração de disparo com um flash crowd de 100 usuários. Botnet bloqueada: fração média de uma botnet injetada de 25 pilhas com A atacantes por janela, ou do tamanho da janela mediana do endpoint (1×), cujas pilhas são ausentes do tráfego (novas) ou tiradas do perfil fora de suas dez impressões digitais mais comuns (compartilhadas); impressões digitais únicas a limitam a cerca de 90%. O escopo z-score é $z > 3$ contra o perfil; a porta de origens é o 99º percentil de origens distintas, calibrado como τ .

e bloqueia em mediana 75 a 80% dos atacantes em toda janela de ataque que Ω sinaliza, sem atingir nenhuma sessão legítima. Com pesos uniformes, Ω pega as mesmas janelas de ataque (78,9% e 85,7%); sem seu termo de endpoint, pega 33,3% e nenhuma, e ainda sinaliza 53 a 100% dos flash crowds. Uma porta sobre origens distintas no seu 99º percentil pega 82,2% e 85,7%, e com o teste também não dispara em nenhuma janela limpa nem flash crowd.

Tráfego de produção. A mesma regra rodou sobre oito dias de logs de acesso dos quatro endpoints dos serviços próprios da operadora cujas janelas têm ao menos $k_{\min}$ origens. Por impressão digital e janela, as exportações trazem os endereços de cliente distintos, as conexões e os pares no mesmo /24, contados dentro do repositório de logs sem que endereço algum saia dele. Cada um dos cinco últimos dias é testado com o perfil, os limiares e λ_e dos dias anteriores, o tráfego limpo exclui clientes bloqueados pelo WAF, e a botnet canônica é injetada nas contagens (Tabela VI). As exportações não trazem prefixos, e por isso o escopo é julgado apenas pelo JA4.

Frotas, como uma frota de sondas ativa apenas em horário comercial, levam λ_e a cerca de 10^{-4} (E4), 10^{-14} (E3), 10^{-60}

(E1) e 10^{-73} (E2), e o escopo sozinho nomeia então um filtro em 1,5 a 6,3% das janelas do dia seguinte. Quando a regra dispara em uma janela limpa de E2 ou E3, ela nomeia uma frota e bloqueia cerca de metade dos clientes dessa janela, e até 70% em uma janela de ataque em que nomeia uma frota junto com a botnet. A porta de origens reduz esses falsos alarmes à metade: as oito janelas limpas que só Ω admite, com o escopo disparando, carregam 33% de seu Ω fora do termo de endpoint, contra 12% nas demais, já que uma frota se concentra em uma impressão digital e eleva o termo TLS justamente onde o escopo erra.

Dois limites travam a detecção. Em E1 com 1 000 atacantes e em E4 no tamanho da janela típica, o escopo nomeia pilhas da botnet na maioria das janelas, mas Ω fica abaixo de τ_{cluster} em 57% e 94% delas; em E2 e E3 as pilhas de uma botnet desse tamanho têm uma ou duas origens, o que nenhum nível calibrado certifica. Com um décimo da janela típica só E1 tem mais de 100 atacantes, e ali o nível calibrado detém o enriquecimento em 0,6%, onde o filtro de inéditos detém 11,2% e o z-score, que dispara em 5,1% das janelas limpas de E1, 12,5%; a união recupera a fatia do filtro de inéditos, e em pilhas compartilhadas só o z-score detém alguma (12,2%).

Um perfil que conhece as frotas do endpoint estreita esse limite. Impressões digitais que o teste nomeia no nível nominal em ao menos 5% das janelas de calibração de um endpoint viram frotas conhecidas, que saem do escopo e da calibração do nível; em E1, cinco ou seis delas, 7% do perfil, fixam o nível, que sobe de cerca de 10^{-60} para 10^{-21} . Fixamos a regra de escolha da fração antes de rodá-la: nos três primeiros dias de teste, a maior fração média bloqueada sem mais falsos alarmes. Nos dois últimos, ela eleva o enriquecimento em E1 com um décimo da janela típica de 0,7% para 6,3% dos atacantes (0,2% para 4,4% em pilhas compartilhadas), com 7 falsos alarmes contra 8. Frações menores bloqueiam mais, mas disparam duas vezes mais, com filtros mais leves e em mais flash crowds, e um atacante que apresente a impressão digital de uma frota conhecida escapa do escopo. Um perfil por hora do dia não ajudou, e $\rho = 2$ ou 5 não move nenhuma taxa agregada de disparo da tabela em mais de 0,3 ponto, nenhuma fração bloqueada em mais de 4,5, e uma mediana de colateral em até 7,2. Flash crowds de 1 000 usuários disparam a regra em 21,8% das janelas e o z-score em 86,8%. No tráfego completo de E3 e E4, 84% e 96% dos clientes que o escopo bloquearia foram também bloqueados pelo WAF, contra 1,5% em E2, cujos filtros nomeiam frotas; E1 não tem atividade de WAF.

APÊNDICE F REPRODUTIBILIDADE

A implementação de referência está disponível em <https://github.com/NatanaelOliveira/knowledge-graph-ddos-article> sob licença permissiva, organizada por estágio: extração (PCAP $\rightarrow$ JA4 e fluxos $\rightarrow$ sessões $\rightarrow$ grafo), o gerador calibrado, a ablação e as linhas de base, a camada simbólica, e os módulos de evidência e mitigação. A consulta de contagens é compilada a partir da ontologia e conferida em sessões

geradas, e todo pacote exportado passa no validador STIX 2.1 da OASIS (`make compile-check stix-check`). As duas derivações de escopo são distribuídas lado a lado, de modo que o resultado negativo da Seção V-D seja reproduzível e não apenas afirmado. Perfis e níveis vêm de execuções livres de ataque, e rótulos entram apenas na avaliação: os scripts por trás da Tabela III tomam o agrupamento de maior Ω sem rótulo algum, e a avaliação por janela não usa nenhum antes da pontuação.

As sementes são fixas e Makefiles conduzem cada estágio, de modo que toda tabela e toda figura de dados se regeneram a partir de um comando, exceto as entradas da Tabela VI, agregados da operadora, cujo resumo anonimizado acompanha o artefato e é conferido contra a tabela. A fonte da Fig. 1 também acompanha, com a ontologia OWL em RDF/XML e toda sub-propriedade `relatedBy` anotada com seu `coordinationWeight`. Pretendemos submeter os artefatos à trilha de Avaliação de Artefatos.